DESARROLLO WEB

Tarea práctica: Protección del inicio de sesión y control de solicitudes
Valor: 8 puntos de zona

Objetivo

Aplicar mecanismos básicos de seguridad en la aplicación web desplegada durante el curso, diferenciando el control de solicitudes (Rate Limiting) del control de intentos fallidos de autenticación. El estudiante deberá implementar, probar y demostrar el funcionamiento de cada medida solicitada.

Controles requeridos

Mecanismo	Qué controla	Regla solicitada
Rate Limiting	Solicitudes	10 peticiones por minuto
Intentos fallidos	Autenticaciones incorrectas	5 contraseñas incorrectas
Bloqueo temporal	Fallos consecutivos	15 min después de 5 fallos
CAPTCHA / Turnstile	Automatización / bots	Validación también en backend

1. Rate Limiting - 2 puntos

Implementar un límite de **10 solicitudes por minuto**. Puede aplicarse al endpoint de login o a otro endpoint del API que permita demostrar claramente el funcionamiento. Al exceder el límite, la aplicación debe rechazar temporalmente nuevas solicitudes. Se recomienda responder con **HTTP 429 - Too Many Requests**.

2. Intentos fallidos - 2 puntos

Registrar los intentos incorrectos de autenticación. El estudiante deberá demostrar que el sistema identifica los fallos consecutivos y controla un máximo de **5 intentos fallidos**.

3. Bloqueo temporal - 2 puntos

Después de **5 intentos fallidos consecutivos**, impedir temporalmente nuevos intentos para la cuenta durante **15 minutos**. El sistema no debe revelar información innecesaria que permita descubrir si una cuenta existe.

4. CAPTCHA / Cloudflare Turnstile - 2 puntos

Agregar CAPTCHA o Cloudflare Turnstile al proceso de autenticación. **No es suficiente colocar el widget en el frontend:** el token o respuesta obtenida debe ser validado por el backend antes de continuar con la autenticación.

Pruebas obligatorias

1. Realizar solicitudes hasta provocar el Rate Limiting y evidenciar la respuesta HTTP 429.
2. Realizar 5 intentos de login con contraseña incorrecta.
3. Comprobar que un nuevo intento queda bloqueado durante 15 minutos.
4. Demostrar CAPTCHA/Turnstile funcionando y su validación en el backend.
5. Explicar durante la demostración la diferencia entre Rate Limiting, intentos fallidos y bloqueo temporal.

Evidencias a entregar

• Código fuente actualizado en el repositorio del proyecto.
• URL de la aplicación desplegada, si se encuentra disponible.
• Capturas o evidencias de las pruebas realizadas.
• Evidencia del HTTP 429 al superar el límite.
• Evidencia de los 5 intentos fallidos y del bloqueo temporal.
• Evidencia de CAPTCHA/Turnstile funcionando y de su validación en el backend.

Rúbrica de evaluación

Criterio	Puntos
Rate Limiting - 10 solicitudes por minuto	2
Control de 5 intentos fallidos	2
Bloqueo temporal de 15 minutos	2
CAPTCHA / Turnstile validado en backend	2
TOTAL	**8**

Importante: No se evaluará únicamente la presencia de código. Para obtener el puntaje de cada criterio, el estudiante deberá demostrar que el mecanismo funciona correctamente y explicar qué riesgo de seguridad busca mitigar.